

Enterprise Architecture Standards — kb-L1-enterprise-architecture v1.0.0

All design/construction agents MUST ground decisions in these standards.

EA1: Technology Stack

Layer	Technology	Version	Purpose
Mobile	Kotlin 2.0, Jetpack Compose 1.7, Material Design 3, AndroidX, CameraX, Room 2.6, WorkManager 2.9, OkHttp 4.12, Retrofit 2.11, Hilt 2.51, Navigation Compose 2.8, Firebase Crashlytics/Performance, Coil 2.6	Latest unless versioned	UI, DI, networking, persistence, background work, monitoring, image loading
Backend	C# 12, .NET 8 Web API, EF Core 8, FluentValidation 11, Serilog 4, Polly 8, MediatR 12, AutoMapper 13 (Approved), Swashbuckle 6	As listed	API, ORM, validation, logging, resilience, CQRS, mapping, OpenAPI
Database	SQL Server 2022, Redis 7.2	As listed	Primary DB, caching
Infrastructure	AKS, Azure API Management, Key Vault, Monitor, DevOps, Service Bus, App Configuration	Latest	Orchestration, gateway, secrets, observability, CI/CD, messaging, feature flags
Testing	xUnit 2.8, NSubstitute 5, Testcontainers .NET, WireMock.Net, Espresso, Compose UI Test	Latest unless versioned	Unit, mocking, integration, HTTP mock, Android UI
Security	SonarQube, OWASP ZAP, Snyk	Latest	SAST, DAST, dependency scanning

RULE: Agents MUST NOT introduce unlisted tech. If needed, output UNLISTED_TECHNOLOGY_REQUIRED: [name] for ARB review.

EA2: Architecture Patterns

Backend: Clean Architecture (4 layers, inward dependency only)

- Domain** — Entities, value objects, domain events, repository interfaces. Zero external deps.
- Application** — Use cases/handlers (MediatR), DTOs, validators (FluentValidation). Depends on Domain only.
- Infrastructure** — EF Core DbContext, repo implementations, external clients. Implements Domain/Application interfaces.
- Presentation** — Controllers, middleware, filters. Entry point; depends on Application.

Mobile: MVVM + Unidirectional Data Flow

ViewModel (Hilt) → StateFlow → Compose UI. Repository pattern. Room for persistence. WorkManager for background sync. Navigation Compose for routing.

Communication

- Sync (REST/HTTPS):** Client-to-server.
- Async (Service Bus):** Inter-service events (application-submitted, kyc-completed, offer-generated).
- Event-driven:** All status changes propagated via events.

State Management

- Server: State machine** — Draft-Submitted-Verifying-UnderReview-Approved-OfferGenerated-OfferAccepted-Disbursed-Active-Closed
- Mobile:** SavedStateHandle for process death recovery. Room for persistence.

CQRS

- Commands via MediatR `IRequestHandler<TCommand, TResult>` with FluentValidation pipeline.
- Queries via MediatR `IRequestHandler<TQuery, TResult>`, may bypass validation.
- Separate read models for complex queries (dashboards).

DDD

- Bounded contexts: Auth, Products, Applications, KYC, Offers, Loans, Notifications.
- Each owns its schema, entities, events. Cross-context via domain events (Service Bus).
- Shared kernel: Money, DateRange, Address in shared library.
- Anti-corruption layer for third-party integrations.

Solution Structure

Backend: `src/LoanApp.{Domain|Application|Infrastructure|Api|Shared}/ + tests/LoanApp.{Domain|Application|Infrastructure|Api}.Tests/`
Mobile:
`app/src/main/java/com/loanapp/{core|data|domain|ui/{auth|products|application|kyc|offer|dashboard|notifications|components|theme}|work`

Error Handling

Backend: Global exception middleware → RFC 7807 **ProblemDetails**. `BusinessRuleViolation-422`, `NotFound-404`, `Conflict-409`, `ValidationFailure-400`, `DBTimeout-503`, `ExternalFailure-502`, `Unhandled-500` (correlation ID, no stack trace). **Mobile:** `Result<T>` sealed class (Success/Error). Repository catches all exceptions. `ViewModel` maps to `UiState` (Loading/Success/Error). User-friendly messages + retry. Technical details to Crashlytics.

Rules

- All backend services MUST follow Clean Architecture layers
- All mobile screens MUST use `ViewModel` + `StateFlow`
- No direct DB access from controllers/screens
- Inter-service communication via defined events only
- Backend exceptions → `ProblemDetails` via global middleware
- Mobile API calls → `Result` (no raw exceptions in `ViewModel`)

EA3: API Standards

Spec: OpenAPI 3.0 required. **Base URL:** `/api/v{version}/{resource}`. **Versioning:** URL path (v1, v2). Breaking changes = new version.

Method	Usage	Code	Meaning
GET	Read	400	Validation
POST	Create/action	401	Unauthenticated
PUT	Full replace	403	Forbidden
PATCH	Partial update	404	Not found
DELETE	Soft delete only	409	Conflict/idempotency
		422	Business rule violation
		429	Rate limited
		500	Internal error
		503	Service unavailable

Format: JSON, camelCase, ISO 8601 dates. Envelope: `{data, meta: {page, pageSize, totalCount}, errors: []}`. Errors: RFC 7807. **Rate Limits:** Read 100/min, Write 20/min per user. 429 + `Retry-After`. **Idempotency:** All POST/PUT/PATCH accept `Idempotency-Key` header. Server caches result 24hr. Duplicates return cached response. **Naming:** Plural nouns (`/products`, `/applications`). **Actions:** `POST /resources/{id}/action`. **Nested:** `/applications/{id}/documents`. **Query params:** camelCase.

Headers

Request: `Authorization: Bearer {jwt}`, `Content-Type: application/json`, `Accept: application/json`, `X-Correlation-Id` (auto-gen UUID), `Idempotency-Key` (client UUID), `X-Device-Id` (mobile), `Accept-Language` (default en-GB). **Response:** `X-Correlation-Id` (echo), `X-RateLimit-{Limit|Remaining|Reset}`, `Cache-Control`, `ETag`.

File Upload

`POST /resources/{id}/documents`, `multipart/form-data`. Max 10MB/file, 25MB/request. Types: jpeg, png, pdf. Virus scan before storage. Response: 201 + metadata.

Health Checks

- `GET /health` — liveness (200 if running, no deps).
- `GET /health/ready` — readiness (checks DB, Redis, Service Bus). 200/503.

Rules

- OpenAPI spec BEFORE implementation
- RFC 7807 for all errors
- All writes support idempotency
- No PII in URLs/query params
- Plural noun resource names
- `X-Correlation-Id` on all requests
- File uploads virus-scanned

EA4: Data Architecture

DB: SQL Server 2022 + EF Core 8. One schema per bounded context: `auth`, `products`, `applications`, `kyc`, `offers`, `loans`, `notifications`. No cross-schema joins.

Naming

Tables: PascalCase plural (`LoanApplications`). Columns: PascalCase (`FirstName`). FKs: `{Table}Id`. Indexes: `IX_{Table}_{Column}`.

Required Columns (every table)

`Id` (UNIQUEIDENTIFIER, PK, NEWSEQUENTIALID), `CreatedAt` (DATETIMEOFFSET, NOT NULL), `CreatedBy` (NVARCHAR(100)), `UpdatedAt` (nullable), `UpdatedBy` (nullable), `IsDeleted` (BIT, default 0), `Version` (ROWVERSION).

Soft Delete: All deletes set `IsDeleted=1`. Hard delete only for GDPR erasure (requires audit entry).

Encryption

PII encrypted at app level (AES-256) before storage: `NationalId`, `DateOfBirth`, `PhoneNumber`, `Email`, `Address`, `IncomeDetails`, `BankStatements`. Keys in Key Vault.

Migrations

EF Core code-first. Naming: `V{N}__{Description}.cs`. All idempotent. Rollback script required.

Caching (Redis)

Product catalog: 1hr TTL, cache-aside. Session data: 15min TTL. Invalidate on write.

Data Classification

Public (product catalog, rates), Internal (app status, config), Confidential (name, email, employment), Restricted (`NationalID`, income, bank statements, biometrics).

Connection & Performance

Pool: min 0, max 100/instance. Timeouts: 30s connect, 30s command (60s reporting). Connection string in Key Vault via App Configuration.

- No `SELECT *` — always `.Select()` projections
- Indexes on: all FKs, WHERE columns, ORDER BY columns
- `.AsNoTracking()` for read-only queries
- Pagination required (max 100/page)
- `.Include()` for related entities (no lazy loading)
- Complex aggregations via raw SQL/stored procs

Transaction Isolation

Standard reads: Read Committed. Financial operations: Serializable. Reporting: RCSI.

Backup

Full daily 02:00 UTC, differential 6-hourly, transaction log 15-min (RPO <15min). 30-day retention. Geo-redundant. Monthly restore test.

EF Core Conventions

One `IEntityTypeConfiguration<T>` per entity in `Infrastructure/Persistence/Configurations/`. Global query filter: `.HasQueryFilter(e => !e.IsDeleted)`. Value converters for encrypted fields. Owned types for value objects.

Zero-Downtime Migrations

- All schema changes backward-compatible with previous app version
- Additive only per release: add columns (nullable/default), tables, indexes
- Destructive changes (remove/rename column): 2-release process (add new + write both + backfill → remove old)
- Migrations run as K8s init container. Failure → rollback deployment
- Large tables (>1M rows): online schema change tools
- Backfill: separate job, not in migration

Rules

- All PII encrypted at rest

- All tables MUST have audit columns
- No cross-schema joins
- Soft delete only (except GDPR)
- Parameterized queries only (EF Core default)
- No SELECT * — project specific columns
- All lists paginated (max 100)
- Financial operations: Serializable isolation

EA5: Security Architecture

Authentication

OAuth 2.0 Authorization Code + PKCE (mobile). JWT: RS256, 15-min expiry. Refresh tokens: opaque, 24hr, rotated on use, device-bound. Biometric via AndroidX BiometricPrompt + Android Keystore.

Authorization

Roles: Customer, Agent, Admin, System. Claims-based fine-grained. API Gateway validates JWT sig + expiry. Backend validates claims + roles.

Password Policy

Min 12 chars, mixed case + number + special. BCrypt (factor 12). Lockout: 5 failures → 30-min progressive. History: last 5 blocked.

OTP

6-digit, 90s expiry, single-use. Rate: 3/10min per phone/email. SHA-256 hashed in storage.

Transport

TLS 1.2+ mandatory. Certificate pinning (mobile, backup pin). HSTS. No mixed content.

API Security

Service-to-service: API key. User-to-service: JWT. CORS: known origins. Headers: CSP, X-Content-Type-Options: nosniff, X-Frame-Options: DENY.

PII Handling

No PII in: logs, URLs, error messages. PII masked in non-prod. Data minimization.

Session Management (Multi-Device)

Max 3 concurrent sessions (FIFO eviction). Each bound to device fingerprint. New device triggers push notification + optional SCA. User can view/revoke sessions. Cross-country login within 1hr → fraud review + SCA.

Secrets Management

Key Vault for all secrets (DB strings, API keys, encryption keys, JWT signing). No secrets in code/config/env vars. Rotation: JWT keys 90 days, API keys 180 days, DB passwords 90 days.

Input Validation

FluentValidation at API boundary. Strings: max length, HTML stripped. Numerics: range validation. Files: magic bytes + size + virus scan. Mobile: client-side for UX, server-side is truth.

OWASP Top 10

A01(Access Control): role+claims+JWT. A02(Crypto): AES-256 rest, TLS transit, Key Vault. A03(Injection): parameterized queries. A04(Insecure Design): threat modeling. A05(Misconfig): hardened containers, security headers. A06(Vulnerable Components): Snyk CI. A07(Auth Failures): OAuth+PKCE, MFA, lockout. A08(Data Integrity): signed JWTs. A09(Logging): structured, no PII. A10(SSRF): no user URLs server-side, allowlist.

Mobile Security

Root detection (warn, block biometric). Screenshot prevention (FLAG_SECURE on sensitive screens). Play Integrity API. Certificate pinning + backup. No sensitive data in backups. R8/ProGuard obfuscation.

Dependency Vulnerability

Snyk on every PR (block critical/high). Weekly Renovate PRs. Quarterly manual review. No critical CVEs in prod.

Rules

- All endpoints require auth (except /health, /products public)
- All PII encrypted at rest + transit
- No secrets in code/config
- Biometric data MUST NOT leave device
- All auth events audit logged
- Server-side validation mandatory
- Sensitive screens: FLAG_SECURE
- All PRs pass Snyk scan

EA6: Infrastructure & Deployment

Container Orchestration (AKS)

One namespace per env: dev, staging, prod. Resource limits on all pods. HPA on CPU/memory.

API Gateway (Azure API Management)

Rate limiting, JWT validation, request/response transformation, versioning, developer portal.

CI/CD (Azure DevOps)

Trunk-based dev + short-lived feature branches. Branch naming: feature/{jira-key}-{description}, aava/{agent-generated}. PR required for main (1 approval, all CI pass). Pipeline: Build → Unit Test → SAST (SonarQube) → Container Build → Integration Test → DAST (ZAP) → Deploy Staging → Smoke Test → Deploy Prod (manual gate) → Post-deploy verify

Environments

dev (auto on PR merge), staging (auto on release branch), prod (manual gate). All use same container images, different config via App Configuration.

Database Deployment

EF Core migrations as K8s init container. Forward-only with backward compatibility.

Mobile Deployment

Android App Bundle via Play Console. Rollout: Internal → Closed beta → Open beta → Prod (1%→10%→50%→100%). Firebase App Distribution for internal builds.

Container Standards

Base: mcr.microsoft.com/dotnet/aspnet:8.0-alpine. Multi-stage build. Size < 200MB. Non-root user. Trivy scan on build. Cosign image signing.

K8s Resources

Resource	CPU Req/Limit	Memory Req/Limit
API service	250m/500m	256Mi/512Mi
Background worker	100m/250m	128Mi/256Mi
Redis	100m/250m	128Mi/256Mi

PDB: minAvailable 1. Replicas: 2-10 (HPA). Liveness: /health 10s, threshold 3. Readiness: /health/ready 5s, threshold 3.

Network Policies

Default deny ingress. Allow: Gateway→API(8080), API→SQL(1433), API→Redis(6379), API→ServiceBus(5671). No direct pod-to-pod outside policies.

DR

Active-passive (Azure paired regions). DB geo-replication + auto failover. Redis geo-replication. Service Bus geo-DR. DNS failover via Traffic Manager. Quarterly DR drill.

Rules

- All deploys via CI/CD (no manual)
- All containers MUST have resource limits
- All envs use same images

- Prod requires manual gate
- Containers run non-root
- Images pass vulnerability scan
- All services have PDB

EA7: Non-Functional Requirements

Performance

API p95 < 500ms, p99 < 1000ms. App cold start < 2s, warm < 500ms. Form completion < 5min. DB query p95 < 100ms.

Availability

99.95% (≤22min downtime/month). RTO < 1hr. RPO < 15min. Health endpoints: /health (liveness), /health/ready (readiness).

Scalability

10K concurrent users. 1K applications/hour. HPA via AKS. DB read replicas for reporting.

Resilience

Circuit breaker on all external calls (Polly). Retry: exponential backoff 1s/2s/4s, max 3. Bulkhead isolation. Graceful degradation (KYC down → allow save, block submit). Timeouts: 30s API, 60s file upload.

Mobile Resilience

Offline form saving (Room). Background sync (WorkManager). Crash recovery (SavedStateHandle + Room). Network detection (ConnectivityManager). Exponential backoff retry.

Accessibility

WCAG 2.1 AA. TalkBack support. Min 48dp touch targets. Dynamic text sizing. High contrast. Logical focus order. contentDescription on all interactive elements.

Rules

- APIs MUST meet p95 < 500ms
- External calls MUST have circuit breaker + retry
- Mobile forms MUST support offline save
- All screens MUST be WCAG 2.1 AA

EA8: Integration Patterns

Sync (REST)

Mobile → API Gateway → Backend. Used for user actions + data retrieval. Timeout 30s, client retry with backoff.

Async (Service Bus Topics)

Topic	Events
application-events	submitted, approved, rejected
kyc-events	started, completed, failed
offer-events	generated, accepted, declined, expired
loan-events	created, payment.due, payment.received
notification-events	send

Dead letter queue, max delivery 5.

Event Schema

```
{eventId, eventType: "domain.action", source, timestamp (ISO8601), correlationId, data: {}, metadata: {version, userId}}
```

Third-Party Integrations

Integration	Protocol	Pattern	Fallback
KYC provider	REST	Async callback	Queue for retry
Credit bureau	REST	Synchronous	Block submission
SMS gateway	REST	Fire-and-forget	Queue and retry

Integration	Protocol	Pattern	Fallback
FCM (push)	REST	Fire-and-forget	Queue and retry
Address Lookup	REST	Synchronous, cached	Manual entry

All wrapped in circuit breaker.

Webhook Standards (Inbound)

Endpoint: `POST /api/v1/webhooks/{provider}`. Auth: HMAC signature verification. Idempotency via event ID dedup. Return 200 immediately, process async via queue. Log all (no PII). Alert on delivery rate drop or signature failure spike.

Rules

- Inter-service communication via defined event topics
- Events follow canonical schema
- All third-party calls have circuit breaker + fallback
- No direct service-to-service REST (use events or Gateway)

EA9: Observability Standards

Logging (Serilog)

Structured JSON. Correlation ID on every entry. NO PII. Levels: Debug (dev only), Information (req/res summary), Warning (degraded/retry), Error (failed op), Fatal (crash). Format: `{timestamp, level, correlationId, service, message, properties, exception}`

Metrics (Azure Monitor + App Insights)

`request_duration_ms` (histogram), `request_count` (counter by endpoint/status), `active_connections` (gauge), `error_rate` (counter), `circuit_breaker_state` (gauge/dep), `queue_depth` (gauge/topic), `cache_hit_ratio` (gauge).

Tracing

OpenTelemetry. W3C Trace Context headers. Spans for: HTTP requests, DB queries, cache ops, message pub/consume, external API calls.

Alerting

Priority	Condition	Action
P1 (page)	Error >5% 5min, p95 >2s 5min, unavailable	Page on-call
P2 (ticket)	Error >1% 15min, p95 >1s 15min, circuit open	Create ticket
P3 (dashboard)	Cache hit <80%, queue >100	Dashboard

Dashboards

Service health (rate, errors, latency, availability). Business (applications/hr, approval rate, processing time). Infra (CPU, memory, pods, nodes).

Mobile Observability

Firebase Crashlytics (crashes). Firebase Performance (render time, network latency). Custom events: `form_step_completed`, `application_submitted`, `offer_viewed`, `offer_accepted`.

Rules

- All services emit structured logs with correlation ID
- All services expose `/health` and `/health/ready`
- All external calls have tracing spans
- No PII in logs, metrics, or traces

EA10: Mobile Architecture

MVVM + Clean Architecture

UI (Compose + ViewModels) → Domain (use cases, models) → Data (repos, Room DAOs, Retrofit APIs). DI via Hilt.

Navigation

Navigation Compose, type-safe args. Deep link support. Single Activity. NavHost with nested graphs: auth, products, application, kyc, offer, dashboard, notifications, settings.

State

ViewModel → StateFlow<UiState>. UiState sealed: Loading, Success, Error. One-time events via SharedFlow. No LiveData.

Networking

Retrofit 2.11 + OkHttp 4.12. Single RetrofitClient (Hilt singleton). OkHttp Authenticator for token refresh. CertificatePinner. Debug-only request logging.

Storage

Store

Room 2.6

EncryptedSharedPreferences

Android Keystore

Usage

Drafts, cached products, notification prefs

Tokens, sensitive config

Biometric credentials

No plain SharedPreferences for sensitive data.

Background (WorkManager)

Form sync: OneTimeWork, REPLACE. Notification token refresh: Periodic 24hr. Offline queue: OneTimeWork, constraint NetworkType.CONNECTED.

Image

CameraX for capture. Coil for loading/caching. Compress to max 2MB before upload. Strip EXIF (privacy).

Build

Variants: debug, staging, release. R8/ProGuard for release. BuildConfig for API base URL per env.

Rules

- All screens use ViewModel + StateFlow
- No direct API calls from Compose
- Sensitive data → EncryptedSharedPreferences or Keystore
- Images strip EXIF before upload
- All network via single RetrofitClient

EA11: Design System Standards

Framework

Jetpack Compose + Material Design 3.

Atomic Design

Level

Components

Atoms Button, TextField, Icon, Text, Divider, Spacer

Molecules FormField (label+input+error), SearchBar, ProductCard, StatusBadge

Organisms RegistrationForm, ApplicationWizardStep, OfferSummary, PaymentTimeline

Templates AuthTemplate, FormTemplate, DashboardTemplate

Pages LoginPage, ProductListPage, ApplicationFormPage

Theming

MaterialTheme with custom ColorScheme (light+dark). Primary: brand blue. Secondary: teal. Error: red. Typography: Display (hero numbers), Headline (sections), Title (cards), Body (content), Label (forms/buttons). Spacing: 4dp base (4, 8, 12, 16, 24, 32, 48). Border radius: 4dp buttons, 8dp cards, 12dp modals, 16dp bottom sheets.

Component Standards

- All: @Preview (light+dark), contentDescription on interactive elements
- Buttons: min 48dp touch target
- TextFields: validation states (default, focused, error, disabled)
- Loading: Skeleton composable (not spinner)
- Error: message + retry action

Icons

Material Icons (filled). Custom only when Material lacks. Sizes: 24dp standard, 20dp dense, 48dp primary actions.

Animation

Compose APIs only: `animateContentSize`, `AnimatedVisibility`, `animateFloatAsState`. Duration: 200ms micro, 300ms transitions, 500ms page. Easing: `FastOutSlowIn` (enter), `FastOutLinearIn` (exit).

Rules

- All components follow atomic hierarchy
- Light + dark theme support
- 48dp minimum touch target
- @Preview required

EA12: Compliance Architecture

FCA Consumer Duty

All fees displayed transparently. Plain-language terms alongside legal text. Total cost visible before accepting. 14-day cooling-off communicated. Early repayment rights prominent.

Lawful basis: Contract (application), legitimate interest (fraud), consent (marketing). Data minimization. Rights: access (download data), erasure (hard delete + audit), portability (machine-readable export). Consent: granular per purpose, marketing OFF by default.

PSD2 SCA

Required for: loan acceptance, payment initiation, viewing sensitive financial data. Two factors from: knowledge (password), possession (device/OTP), inherence (biometric). Exemptions: product catalog, own application status.

PRA Operational Resilience

Important Business Services: loan processing, disbursement, payment collection. Impact tolerances defined. Third-party dependency mapping. Regular scenario testing.

DORA

ICT risk management. Incident classification + reporting (major within 4hr). Third-party provider register. Regular resilience testing. Cyber threat sharing.

Data Retention

Data	Period
Application data	7yr after loan closure
Rejected applications	3yr
KYC documents	5yr after relationship end
Audit logs	7yr
Marketing consent	Duration + 1yr

Audit Trail

Separate audit schema, append-only (no UPDATE/DELETE). Async writes via queue (<5s eventual consistency). Schema: `{auditId, timestamp, userId, action (CREATE|READ|UPDATE|DELETE|LOGIN|LOGOUT|EXPORT|CONSENT_CHANGE), resource, resourceId, changes: {field: {old, new}}, reason, ipAddress (masked), correlationId, outcome}` What to audit: all PII access, all state transitions, all auth events, all consent changes, all data exports, all admin actions. Retention: 7yr (cold storage after 2yr). Read-only API for compliance. Audit queries themselves logged.

Rules

- Fee displays show ALL fees (total cost)
- All PII processing has documented lawful basis
- Sensitive actions require SCA (two-factor)
- Important business services have impact tolerances
- All data has retention period + automated cleanup

EA13: Code Standards

Backend (C#) Naming

Element	Convention	Example
Classes/Methods/Properties	PascalCase	<code>LoanApplicationService.SubmitApplication()</code>

Element	Convention	Example
Interfaces	I-prefix	<code>ILoanApplicationRepository</code>
Private fields	<code>_camelCase</code>	<code>_applicationRepository</code>
Constants	PascalCase	<code>MaxRetryCount</code>
Enums	PascalCase singular	<code>ApplicationStatus.Submitted</code>
Async methods	Async suffix	<code>SubmitApplicationAsync()</code>

Mobile (Kotlin) Naming

Element	Convention	Example
Classes/Composables	PascalCase	<code>ApplicationFormViewModel, ApplicationFormScreen()</code>
Functions/Properties	camelCase	<code>submitApplication(), applicationStatus</code>
Constants	SCREAMING_SNAKE	<code>MAX_RETRY_COUNT</code>
State	camelCase + Flow	<code>applicationStateFlow</code>
Room entities	PascalCase + Entity	<code>ApplicationDraftEntity</code>
Room DAOs	PascalCase + Dao	<code>ApplicationDraftDao</code>

Documentation

Public APIs: XML doc (C#) / KDoc (Kotlin). Complex logic: inline WHY comments. DTOs: property docs for non-obvious fields. README.md per project root.

Quality

SonarQube gate: 0 critical, 0 high, <5 medium. Coverage: 80% Application, 60% Infrastructure. Cyclomatic complexity max 10/method. Method max 30 lines. Class max 300 lines. No TODO/FIXME in main.

Rules

- Public APIs MUST have doc comments
- Code MUST pass SonarQube gate
- Async methods use Async suffix (C#)
- No TODO/FIXME in main branch

EA14: Testing Standards

Test Pyramid

Level	Framework	Coverage	Speed
Unit	xUnit+NSubstitute (C#), JUnit+MockK (Kotlin)	80% Application	<1s
Integration	Testcontainers+WireMock	All API endpoints	<5s
Contract	OpenAPI validator	All endpoints match spec	<1s
E2E (Mobile)	Espresso+Compose UI Test	Critical paths	<30s
Security	OWASP ZAP	All endpoints	Nightly
Performance	k6	p95 targets under load	Weekly

What to Test

Unit: domain entities (rules, state, validation), handlers (logic, edges, errors), validators (rules, boundaries), value objects. Integration: endpoints (happy, validation, auth, 404), DB (migrations, queries, concurrency), external services (circuit breaker, retry, fallback). Mobile UI: form validation, navigation (deep links, back stack), offline (save, sync, errors), accessibility (TalkBack, focus, targets).

Test Data

Factory pattern (`ApplicationFactory.CreateSubmitted()`). No prod data. Testcontainers for fresh DB. WireMock for external APIs. Fake data: John Doe, 07700900000, AA000000A.

Naming

C#: `MethodName_Scenario_ExpectedResult`. Kotlin: backtick descriptive names.

Rules

- Application handlers MUST have unit tests (80%)
- All API endpoints MUST have integration tests
- Critical flows MUST have E2E tests
- Synthetic data only (no production)

- All PRs pass all tests

EA15: Feature Flag Standards

Platform

Azure App Configuration + Feature Management. .NET: `Microsoft.FeatureManagement`. Mobile: flags fetched on launch, cached 1hr.

Naming

`{context}.{feature}.{variant}` — e.g., `loans.earlyRepayment.enabled`, `kyc.livenessCheck.v2`.

Types

Type	Use	Example
Release	Gradual rollout	<code>loans.offerComparison.enabled</code>
Ops	Kill switch	<code>kyc.provider.enabled</code>
Experiment A/B test		<code>ui.offerScreen.variant</code>
Permission	Role/tier access	<code>loans.premiumProducts.enabled</code>

Lifecycle

Created OFF → code deployed behind flag (both paths tested) → enable: internal → staging → 1% → 10% → 50% → 100% → stable 2 sprints → remove flag + code cleanup. Max lifetime: 90 days (except ops).

Rules

- New features MUST be behind flag
- Flags MUST have owner + expiry
- Both paths tested
- Ops toggles documented in runbooks

EA16: Dependency Management

Adding Dependencies

1. Check EA1 approved stack. If not listed → `UNLISTED_TECHNOLOGY_REQUIRED`.
2. License check: MIT, Apache 2.0, BSD allowed. GPL/AGPL/SSPL/Commons Clause prohibited.
3. Snyk vulnerability check.
4. Maintenance: last commit <6mo, active maintainers.
5. Pinned version (no floating). Document in PR: why, alternatives, license.

Updating

Automated weekly PRs (Renovate). Patch: auto-merge if tests pass. Minor: manual review, merge within 1 sprint. Major: ARB review + dedicated story.

Rules

- Compatible licenses only (MIT, Apache 2.0, BSD)
- Pinned versions (no wildcards)
- Updates pass vulnerability scan
- GPL/AGPL PROHIBITED

EA17: Documentation Standards

Required Docs

Document	Owner	Location	Updated
ADRs	Tech Lead	<code>/docs/adr/</code>	On decision
API docs	Backend dev	Auto from OpenAPI	On API change
DB schema	Backend dev	Auto from EF Core	On migration
Runbooks	DevOps	Confluence	On infra change
Onboarding	Tech Lead	<code>/docs/onboarding.md</code>	Quarterly
Postmortems	On-call engineer	Confluence	Within 48hr

ADR Format

ADR-{NNN}: {Title} → Status (Proposed|Accepted|Deprecated|Superseded) → Context (issue) → Decision (change) → Consequences (easier/harder). Required for: tech choices, architecture changes, security decisions, third-party integrations. Immutable once accepted (supersede with new ADR).

Rules

- Architecture decisions MUST have ADR
- APIs MUST have auto-generated docs from OpenAPI
- Incidents MUST have postmortem within 48hr
- Runbooks reviewed quarterly

EA18: Notification Architecture

Channels

Channel	Tech	Use Case	SLA
Push	FCM (Android)	Real-time: status changes, reminders, security	<30s
Email	SendGrid / Azure Comms	Transactional: confirmations, statements, regulatory	<5min
SMS	Twilio or equivalent	OTP, critical alerts when push unavailable	<10s
In-app	Local store + badge	Non-urgent: marketing, updates, tips	Next app open

Categories

Category	Opt-out	Examples
Security	No	OTP, new device login, password change, logout
Regulatory	No	Arrears (CCA s.86B), rate changes, annual statements
Transactional	No	Application status, payment confirm, disbursement
Service	Yes (per channel)	Payment reminders, offer expiry, document ready
Marketing	Yes (default OFF, GDPR consent)	New products, promo rates, referrals

Event Schema

```
{notificationId, userId, category, channel, template, data: {variables}, priority (high|normal|low), scheduledAt, expiresAt, deepLink, correlationId}
```

Preferences

Per category + per channel (except Security/Regulatory = always on). Stored in DB, cached Redis 15min. Marketing requires separate GDPR consent. Changes immediate (cache invalidated).

Templates

All content via templates (not hardcoded). Versioned: {name}-v{N}. Variables: {{customerName}}, {{amount}}. Compliance review for regulatory. Multi-language per locale.

Delivery

Push: fire-and-forget via FCM (invalid token → re-register). Email: async queue, retry 3x backoff, track delivery. SMS: async queue, retry 2x. Failed: log to audit, no infinite retry.

Deep Linking

Every notification includes deep link. Format: loanapp://route/path. App killed state: Navigation Compose deep links. Not installed: app store / web fallback.

Rules

- Security/Regulatory NOT opt-out-able
- Marketing OFF by default (explicit consent)
- All content via templates
- All notifications include deep link
- All deliveries audit-logged
- No PII in push titles (lock screen visible)

EA19: PCI-DSS

Approach

Tokenisation via PCI-DSS Level 1 certified payment processor. Application NEVER stores/processes/transmits raw card data. SAQ Level: SAQ A.

Card Data Rules

Element	Store	Display	Notes
Full PAN	NEVER	NEVER	Processor only
Masked PAN (last 4)	Yes	Yes	**** * 1234
Cardholder name	Yes (encrypted)	Yes	For CoP matching
Expiry/CVV	NEVER	NEVER	Processor only
Token	Yes	No	Recurring payments

Implementation

1. Card capture: processor's hosted fields/SDK (iframe — never touches our systems)
2. Tokenisation: processor returns token, stored in our DB
3. Recurring: use stored token via processor API
4. Updates: processor handles via Account Updater

Processor Integration

TLS 1.2+ API. Keys in Key Vault. HMAC-signed webhooks. Idempotency key on all payment requests.

3D Secure (SCA)

All card payments support 3DS2. Processor handles challenge flow. Exemptions: recurring after initial SCA, low-value (per PSD2 RTS).

Rules

- Raw card data (PAN, expiry, CVV) MUST NEVER touch our systems
- Card capture via processor hosted fields/SDK
- All tokens encrypted
- All payments support 3DS2
- SAQ A compliance audited annually

EA20: Localisation & Multi-Platform

i18n

Default locale: en-GB. All user-facing strings externalised (no hardcoded text). Android: `res/values/strings.xml` + locale variants. Backend: error messages + notification templates with locale key.

- Dates: stored UTC, displayed in user timezone, format per locale
- Currency: stored as minor units (pence/halalas), displayed locale-formatted
- RTL: if Arabic supported, all layouts support RTL (Compose handles via `LayoutDirection`)
- Numbers: locale-aware formatting

Adding Locale

1. Create resource files. 2. Professional translation. 3. Test all screens (layout, truncation, RTL). 4. Add to notification templates. 5. Add to backend error catalogue.

Multi-Platform

Primary: Android (Kotlin/Compose). Future: platform-native (Swift/SwiftUI for iOS, React/Next.js for web). No cross-platform frameworks (Flutter, RN) — ARB decision. API-first: same API serves all. Feature parity across platforms.

Release Management

Android: Play Console (internal → beta → staged prod 1%→100%). iOS (future): TestFlight → phased 7-day. Release: every 2 weeks. Hotfixes ad-hoc. Versioning: major.minor.patch. Force update for critical security. Soft update banner for non-critical.

Rules

- All strings externalised
- Dates stored UTC, displayed in user timezone
- Currency stored as minor units
- RTL layouts tested if RTL locale supported
- Staged rollout (never 100% day 1)

- Force update for critical security fixes